

Termin 2 – Modelle und Messbarkeit der Resilienz

Prof. Dr. Dirk Loomans

29. September 2026

Vorlesungsskript • Grundlagen der Resilienz • Cyber Security Management (B.Sc.), 1. Semester • Hochschule Mainz

Vorbemerkung: Dieses Skript dient als Vorlesungsbegleitung und erhebt keinen akademischen Anspruch. Dennoch kann es bei der Klausurvorbereitung hilfreich sein. Kommentare und Verbesserungsvorschläge gerne an den Autor über dirk.loomans@hs-mainz.de.

Leitfrage

Wie wird Resilienz sichtbar, vergleichbar und steuerbar?

Lernziele

Nach diesem Termin können Studierende

- erklären, warum Resilienz quantitativ und qualitativ messbar gemacht werden muss,
- zentrale Resilienzkennzahlen für IT-Systeme (RTO, RPO, MTTR, MTBF) definieren und einordnen,
- Resilienzmodelle in Normen und Rahmenwerken verorten (NIST, ISO, BSI, ENISA),
- anhand einer Degradations- und Recovery-Kurve die Resilienz eines Systems qualitativ beschreiben,
- erste Reifegrad- und KPI-basierte Bewertungen realer IT-Systeme vornehmen.

Fachinhalte

Rückblick

Safety ≠ Security – beides beeinflusst Resilienz. Vier technische Prinzipien: Redundanz, Diversität, Wiederherstellbarkeit, Adaptivität. Resilienz ist nicht Unverwundbarkeit, sondern Erholungsfähigkeit.

Warum Resilienz messen?

Messbarkeit ist kein Selbstzweck, sondern Voraussetzung für Steuerung, Vergleich und Verbesserung:

1. **Governance und Steuerung** – Führung braucht belastbare Metriken für Priorisierung, Budgetierung und Wirksamkeitskontrolle.
2. **Vergleichbarkeit und Reifegradbewertung** – Fortschritt und Lücken werden systematisch beurteilbar.
3. **Nachweisfähigkeit** – in regulierten Domänen (KRITIS, Finanzmarktaufsicht) wird quantifizierbare Belastbarkeit erwartet.

Hinzu kommen Frühwarnindikatoren für die Krisenfähigkeit.

Resilienz als Systemfunktion

Resilienz ist keine statische Eigenschaft, sondern eine zeitabhängige Systemleistung. Ein System ist nicht „resilient oder nicht“, sondern zeigt ein bestimmtes Verhalten unter Störung. Die Degradations- und Wiederherstellungskurve beschreibt die Systemleistung $L(t)$ über die Zeit:

1. Normalbetrieb, $L(t) \approx 100\%$
2. Störung, Angriff oder Fehler – abrupte oder schleichende Abnahme
3. degradiertes Zustand – reduzierter Servicelevel oder Totalausfall
4. Wiederherstellung – schrittweiser oder sprunghafter Wiederanstieg
5. Rückkehr in den Zielzustand – auf altem oder verbessertem Niveau

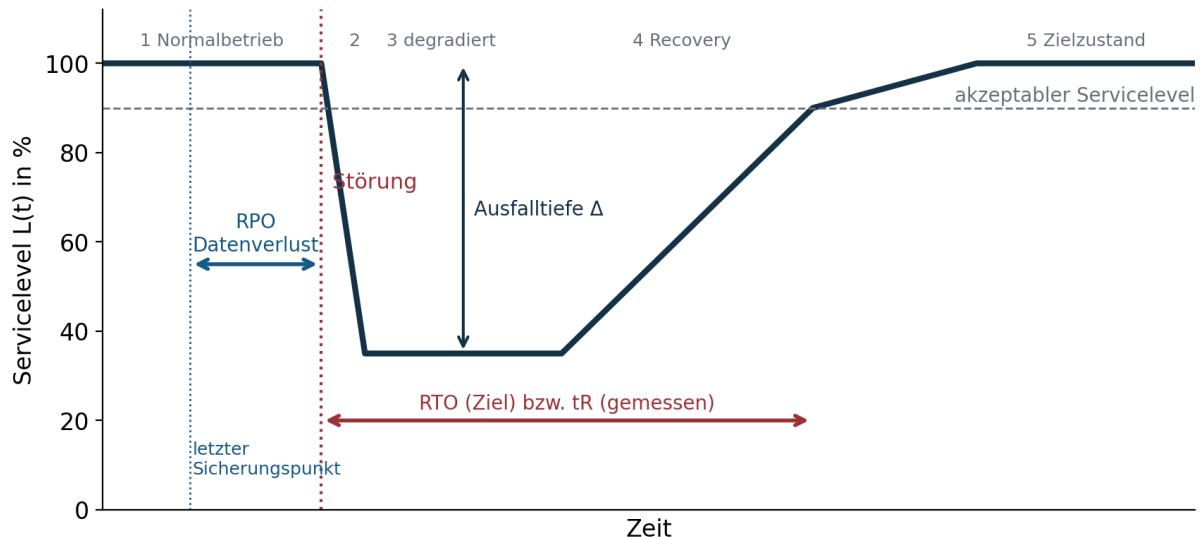


Abbildung 1: Schematische Degradations- und Wiederherstellungskurve mit RPO, RTO und Ausfalltiefe

Die Kenngrößen ergeben sich direkt aus der Kurve: **Ausfalltiefe Δ** (wie weit sinkt der Servicelevel?), **Wiederherstellungszeit t_R** (wie lange bis zum akzeptablen Niveau?), **Datenverlustfenster (RPO)** und **Zieldauer (RTO)**. Ziel ist die Minimierung von Δ und t_R . Resilienz zeigt sich nicht im Normalbetrieb, sondern in der Auslenkung. Der funktionale Ansatz macht technische, organisatorische und menschliche Maßnahmen vergleichbar: Die Kurve misst das Ergebnis, nicht den Weg.

Kennzahlen: RTO, RPO, MTTR, MTBF

Kennzahl	Bedeutung	Beispiel	Typ
RTO – Recovery Time Objective	maximal zulässige Wiederherstellungszeit: „Wie lange dürfen wir offline sein?“	2 h für einen Mailserver	Planungsziel
RPO – Recovery Point Objective	maximal tolerierbarer Datenverlust in Zeit: „Wie alt dürfen die wiederhergestellten Daten sein?“	15 min	Planungsziel
MTTR – Mean Time To Repair	durchschnittliche Reparatur- bzw. Wiederherstellungszeit	45 min	Messwert
MTBF – Mean Time Between Failures	mittlere Zeit zwischen zwei Ausfällen; Maß für Zuverlässigkeit	30 Tage	Messwert

RTO und RPO sind normative bzw. vertragliche Anforderungen, MTTR und MTBF beobachtete Performance. MTBF misst Zuverlässigkeit, nicht Resilienz, ist aber ein entscheidender Parameter der Risikoexposition. In der Praxis ist Resilienz eine Optimierung unter Nebenbedingungen (Kosten, Regulatorik, Kritikalität). Normen fordern Angemessenheit, nicht absolute Minimierung.

Bezug zur Kurve: Das RTO entspricht dem Zeitpunkt, an dem die Kurve den akzeptablen Servicelevel wieder schneidet. Das RPO definiert den Datenverlustbereich vor dem Ereignis.

Modelle aus Frameworks

Framework	Fokus	Kernelemente laut Unterlagen
NIST SP 800-160 Vol. 2	Cyber Resilience Engineering	Resist, Detect, Respond, Recover, Re-constitute, Adapt; Integration in Engineering und Architektur
ISO/IEC 27031	IKT-Bereitschaft für Business Continuity	Vorbereitung, Wiederanlaufplanung, Tests & Übungen, Lessons Learned; Nachweis- und Testbarkeit
BSI-Standard 200-4	Business Continuity Management	Reifegrade, Szenarien, Notfallübungen; bewertet Organisationen, nicht nur Systeme
ENISA	Sektorale Resilienz (KRITIS)	sektorabhängige Bedrohungsmodelle, Abhängigkeiten, Response- und Recovery-Blueprints

Frameworks sind keine Alternative zu Messgrößen, sondern der Ordnungsrahmen, in dem Metriken geplant, bewertet und verbessert werden. **Messgrößen erzeugen Evidenz – Frameworks verankern sie strukturell.**

Hinweis zur Aktualität

Die NIST-Bezeichnungen, die 2025 erschienene Neuauflage von ISO/IEC 27031 und die Stufen des BSI-Standards 200-4 (Reaktiv-, Aufbau-, Standard-BCMS) sind unter [Quellen](#) erläutert.

Messmethoden und KPIs

- **Technisch:** Monitoring, MTTR, Backup-Tests
- **Organisatorisch:** BCM-KPIs, Audit-Indikatoren
- **Subjektiv:** Selbstbewertungen, Reifegradanalysen

Reifegradmodelle

Quantitative Messung beantwortet: „Wie verhält sich das System im Störfall?“, Ein Reifegradmodell beantwortet: „Wie gut ist die Organisation vorbereitet, bevor der Störfall eintritt?“ Reifegradmodelle steuern zukünftige Fähigkeit; sie sind ein Governance-Instrument.

Typischer Entwicklungspfad in fünf Stufen: **Ad hoc** (reaktive Einzelaktionen) – **definiert** (Prozesse existieren, wirken aber noch nicht zuverlässig) – **etabliert** (Rollen, Tests, Nachweise, KPIs verankert)

– **gesteuert** (Messgrößen werden genutzt, Lessons Learned etabliert) – **optimiert** (kontinuierliche Verbesserung, Resilience by Design).

Reifegrad und Metrik gehören zusammen:

- RTO-Ziel existiert, Recovery-Test nie durchgeführt → geringer Reifegrad trotz Kennzahl.
- MTTR sinkt über die Zeit → Hinweis auf lernende Organisation.
- RPO definiert und Backups getestet → Evidenz statt Policy.

Ein hoher Reifegrad ohne gemessene Recovery ist Papiersicherheit; gemessene MTTR ohne organisatorischen Rahmen ist Zufallssicherheit. Resilienz verlangt beides.

Fallbeispiele

- **Ransomware in einer Kommunalverwaltung:** Totalausfall von Fachverfahren und E-Mail, mehrtägiger Notbetrieb. Wiederanlauf nur aus Offline-Backups mit RTO von mehreren Tagen und hohem Datenverlust. Es fehlten Segmentierung, getestete Recovery-Pfade und ein getesteter BC-Plan – niedrige Resilienz trotz vorhandener Backups.
- **AWS-Regionsausfall (2021):** Kunden mit Single-Region-Design waren offline; Multi-Region-Kunden blieben verfügbar oder schwenkten in Minuten. Architektur, nicht Plattform, entscheidet über Resilienz. (Folienbeispiel: RTO 3 h, RPO 30 min; Geo-Redundanz und Failover verkürzen beide.)
- **Cloud-Gaming-DDoS:** Service verlangsamt statt ausgefallen (Rate-Limiting, Warteschlangen); Lastverteilung und Auto-Scaling führen zurück zu stabilem Niveau – Graceful Degradation statt Hard-Fail.

Resilienz bewertet nicht, ob ein Ereignis eintritt, sondern wie ein System danach aussieht.

Übung: Resilienz bewerten

Gruppenarbeit, 20–30 Minuten. Wählen Sie ein reales, allen bekanntes IT-System (Uni-E-Mail, Cloud-Speicher, Banking-App, Cloud-Gaming-Dienst, Krankenhaus- oder Verwaltungs-IT, Smart-Home-Plattform).

1. **Metriken realistisch schätzen:** Welches RTO wäre angemessen? Welcher RPO tolerierbar? Ist die MTTR aus Statusseiten oder öffentlichen Incidents erkennbar?
2. **Reifegrad qualitativ bewerten:** Ad hoc oder professionell vorbereitet? Hinweise auf Übungen, Chaos Engineering, DR-Tests? Redundanz, Diversität oder Single Points of Failure?
3. **Kurzfazit:** Ist das System eher resilient, bedingt resilient oder fragil – und warum?

Ergebnis: 1–2 Folien oder ein strukturiertes Kurzstatement mit höchstens fünf Stichpunkten je Dimension. Ziel ist nicht perfekte Recherche, sondern das Denken in Resilienzmetriken und der Unterschied zwischen *gefühlter* sicher und *nachweislich resilient*.

Prüfungsrelevante Leitfragen

- Wie unterscheidet sich Resilienzmessung von klassischer Sicherheitsbewertung?
- Erklären Sie RTO und RPO und ordnen Sie deren Funktion im BCM-Kontext ein.
- Wie verortet NIST SP 800-160 Vol. 2 Resilience Engineering im Lebenszyklus?
- Welchen Zweck erfüllen Reifegradmodelle, etwa im Umfeld des BSI-Standards 200-4?
- Warum ist Recovery-Übung eine notwendige Bedingung für Resilienz?

Kernbotschaften: Resilienz zeigt sich im Verlauf von Störung und Wiederherstellung. RTO/RPO sind Zielgrößen, MTTR/MTBF Messgrößen – beide sind notwendig. Frameworks schaffen Verbindlichkeit und Vergleichbarkeit. Reifegradmodelle bewerten Fähigkeit vor dem Ereignis. Resilienz ist eine Eigenschaft von Architektur, Organisation und Übung.

Vor- und Nachbereitung

Hausaufgabe: Recherchieren Sie ein reales IT-Ereignis (z. B. AWS-Ausfall, Ransomware-Vorfall, Rechenzentrumsbrand) und analysieren Sie, wie schnell der Dienst wiederhergestellt wurde und welche Daten gegebenenfalls verloren gingen.

Ausblick Termin 3: Redundanz, Diversität, Wiederherstellbarkeit und Adaptivität in hybrid verteilten Systemen – die Brücke von der Messung zur Architektur.

Material aus dem Archiv

02 Modelle und Messbarkeit/02_Modelle und Messbarkeit der Resilienz.pdf und Grundlagen der Resilienz 2.pdf (Skript).

Bibliografie